EWB Courses: AI-Powered Cybersecurity

Assessment 01: Security Foundations

Name: Gopal Mankar

Batch/Group: Ewb AI POWERED CYBERSECURITY INTERNSHIP - Batch 1

Date: 30/10/2026

Task A: Secure a Student Account

Scenario: Mira uses the same short password for her email and learning portal. She approves unexpected sign-in prompts, postpones device updates and keeps her only project copy on one laptop. A friend sometimes uses that laptop under Mira's signed-in account.

In my class notes, a vulnerability is a weakness and a threat is something that could cause harm. Each risk below is a weakness in Mira's habits that a threat could use.

A1 and A2: Risks and controls

#	Risk	Asset at risk	CIA impact	Practical control	Limitation
1	Same short password for email and portal	Email and learning portal accounts	**Confidentiality, Integrity:** A short password is easy to guess. If it leaks, an attacker could read her emails and change her academic data on both accounts.	Use a password manager to make and store a long, unique password for each account.	If the master password is lost or stolen, all stored passwords are affected.
2	Approves unexpected sign-in prompts	Account access and sessions	**Confidentiality, Integrity:** An unexpected prompt may mean someone is trying to sign in with her password, though the prompt alone does not prove it. If Mira approves it, that sign-in is allowed and her data or settings could be exposed.	Turn on number-matching MFA, where she types a number shown on the login screen. Deny any prompt she did not start.	The system and app must support number-matching. MFA lowers risk but cannot stop every compromise.
3	Postpones device updates	Laptop (system and files)	**Confidentiality, Integrity, Availability:** Old software has known flaws. Malware or ransomware can use them to steal, damage or lock her files.	Turn on automatic updates for the system and key apps.	Updates can cause bugs or restarts that interrupt work.
4	Only project copy is on one laptop	Project files	**Availability:** If the laptop is lost, stolen or fails, she may lose the only copy.	Use automatic cloud sync (OneDrive or Google Drive) for project folders.	Needs internet and storage space. Sync can also copy deleted or damaged files, so keep version history or a second backup.

#	Risk	Asset at risk	CIA impact	Practical control	Limitation
5	Friend uses the laptop under her signed-in account	Her session and local files	**Confidentiality, Integrity:** The friend can read her emails, open portal files or send messages as Mira, on purpose or by mistake.	Make a separate guest account and lock the screen when leaving the laptop.	Depends on Mira's habits. It fails if she forgets to lock the screen.

Priorities

1. **Stop approving unexpected MFA prompts and tell college IT.** This is the most urgent. An unexpected prompt may mean someone has her password, and one approval can let them in within seconds. If she already approved one, she should treat the account as possibly compromised.
2. **Set a unique password and check active sessions.** Change the reused password on the real college portal and ask IT to end suspicious sessions. Change it on any other account where it was reused. This is second because a reused password keeps both accounts exposed until it is changed.
3. **Keep the laptop updated and keep a backup.** Install updates soon, and keep project files where there is version history or a second copy. This is third because it protects against loss and known flaws more than against a quick account takeover. Updates can cause problems, and backups must be tested.

The guest account and screen lock (Risk 5) should follow soon after.

A3: Authentication vs. authorisation

Authentication proves who the user is. When Mira enters her email and password and approves an MFA prompt, the learning portal checks that she is really Mira.

Authorisation decides what the user may do after that. The portal lets Mira view her own courses and submit assignments, but not see other students' grades or change course settings. If her friend uses her signed-in session, the portal treats him as Mira and gives him her permissions.

Task B: Analyse a Suspicious Message

I am assessing only the supplied text and did not visit any address.

B1: Warning signs

#	Phrase or detail quoted	Why it needs scrutiny
1	awards@campus-awards.example (From) and help@personal-awards.example (Reply-To)	The college normally uses campus.example. These domains are different, and replies would go to a third domain. It may be an attempt to look official, but the message alone cannot prove it.
2	"FINAL WARNING - scholarship expires in 20 minutes"	Strong time pressure leaves little time to think. Scammers often use deadlines so people act before checking.
3	"enter your college password and OTP"	**Serious warning sign.** The message is unasked for and wants both secrets through a link. An OTP is meant to confirm a sign-in the real user started. A genuine college is unlikely to ask for both this way. My class notes also say never to share OTPs. It should be verified independently.
4	"Do not contact the college office because their system is unavailable"	It tells the student not to check with a trusted source, so the message cannot be verified.
5	"Reply with a photo of your identity card"	It asks for a sensitive document by email reply. This could expose identity details to misuse.

B2, B3 and B4: Verification and response plan

Safe verification process (B2)

1. Do not click the link or reply. Open a new tab and go to the official campus.example portal from a bookmark to look for notifications.
2. Call the scholarship office using a number from the official website or a college notice, not from the message. Ignore the claim that the system is down.
3. If the office says the message is not genuine, report it to the college IT team or helpdesk.

Why HTTPS or a display name is not enough. A display name such as "Scholarship Desk" can be set to anything. HTTPS only means the connection is encrypted. It does not show that the website belongs to the college, and a look-alike site can also use HTTPS.

If the student already entered a password and OTP (B3)

1. **Immediate containment:** From a trusted device, open the real college portal (bookmark or typed address) and change the password. Sign out other sessions if possible, and check MFA and recovery settings for anything unfamiliar. Change the password on any other account that used it.
2. **Official reporting:** Report it to the college IT team or helpdesk through official channels. Say that an OTP was also entered. Never send the password or OTP to anyone.
3. **Follow-up checks:** Look at recent account activity (sign-in history, sent mail, new MFA devices) for actions the student did not do. If the ID card photo was sent, tell the college office and watch for identity misuse.

Missing evidence (B4)

Missing fact: The message alone cannot show whether it was really sent from a server that owns campus-awards.example, or whether the address was spoofed. **Useful evidence:** the full email headers and the email authentication results (SPF, DKIM, DMARC), which IT can review. These show whether the sender's domain passed checks, but not who the person is. Until the origin is confirmed, the message should be treated as suspicious.

Task C: Triage a Sign-in Alert

All times are IST on 18 October 2026.

C1: Four-point timeline

#	Time	Observation (logs and statement)	Interpretation
1	09:00–09:01	At 09:00 student07 signed in with a password from 192.0.2.10. At 09:01 an MFA approval was recorded from the same IP.	Looks like a normal sign-in. The assessment says 192.0.2.10 is the usual classroom IP, but an IP alone does not show who used the account.
2	10:14–10:16	Password failed twice from 198.51.100.23 (10:14, 10:15), then succeeded at 10:16.	Suspicious, because failures were followed by a success. Someone may have found the right password, but the logs do not show how or who entered it.
3	10:17–10:18	MFA was denied at 10:17 and approved at 10:18. The student says they approved a prompt around 10:18 to stop repeated requests.	Fits a user approving a prompt just to make it stop. The logs do not show who denied the first request.
4	10:20	A session was created at 10:20 from 198.51.100.23.	The sign-in completed. Given the student's statement, it should be treated as possibly unauthorised. The log does not identify the person behind the IP or show what the session did.

C2: Explanations and additional checks

Likely explanation: Someone may have used the student's correct password and got an MFA approval between 10:14 and 10:20. The student says they approved a prompt to stop repeated requests, which fits this. The session at 10:20 shows the sign-in worked, but the evidence does not identify who did it.

Alternative explanation: The sign-in was legitimate. For example, the student's own device or an app signed in from another network, and the failed passwords were typing mistakes. My class notes say an IP address changes when a device joins a different network, so a new IP alone is not unusual. This would not remove the concern from the unexpected MFA approval, so the logs still need checking.

Two checks that could separate the explanations:

1. Check device, browser and session details in the authentication, MFA and session records. If they do not match the student's known devices, the likely explanation gains weight. If they match, the alternative does.
2. Check what happened after 10:20, such as password changes, file downloads, new mail forwarding rules or new MFA devices. Suspicious changes would support the likely explanation.

The IP addresses 192.0.2.10 and 198.51.100.23 are reserved documentation examples. They should not be used to guess a real person's location or identity.

C3: Prioritised response actions for IT

1. **Contain the possible compromise.** End active sessions and tokens, and reset the password through the verified college process. Check MFA methods and recovery settings for anything unfamiliar, and check whether the password was reused elsewhere. Copy the relevant logs first or at the same time so no records are lost.

2. **Preserve evidence.** Keep the available sign-in, MFA, session and account logs with their timestamps. Keep the suspicious email if relevant. Do not delete logs, and do not assume network-traffic records exist if none were given.
3. **Investigate activity after the sign-in.** Review events after 10:20 for unauthorised changes, file access, messages or security-setting changes. Write down the findings and escalate through the college's incident process.

Containment is first because a session may still be active. Evidence is kept alongside it, and the investigation follows.

C4: Incident summary (91 words)

The logs show two failed passwords, then a successful password check at 10:16, an MFA denial at 10:17, an MFA approval at 10:18 and a session at 10:20, all from 198.51.100.23. The student says they did not sign in after 09:05 and approved a prompt to stop repeated requests. This raises concern about unauthorised access, but the logs do not identify the person behind the IP or show what happened next. Priority is high until checked. IT should secure the account, end active sessions, preserve evidence and review activity after 10:20.

Task D: Review an AI Security Answer

D1: Unsafe or unsupported claims and corrections

#	AI claim or action	Correction and evidence
1	"The email is safe because it uses HTTPS."	HTTPS only encrypts the connection. It does not show that the sender or site is trustworthy, and a look-alike site can also use HTTPS. The message also has several warning signs (Task B), so it should be treated as suspicious until verified.
2	"The sign-in logs prove that the person using 198.51.100.23 stole the password."	An IP address cannot identify a person or show who entered the password. The logs show a sequence of sign-in events, not who was responsible. In this assessment the IP is also a reserved documentation example.
3	"MFA prevents every account compromise."	MFA helps a lot but is not perfect. In Task C a prompt was approved after repeated requests, so a user can be tricked into approving. Other attacks can also get around MFA.
4	"Delete the suspicious logs."	Logs are evidence in a security incident. Deleting them makes it harder to find out what happened and what was accessed. They should be kept and copied securely for the authorised IT team.
5	"Send the student's password to support so they can test it."	Passwords must never be shared, even with support. Support should use a secure password reset and end suspicious sessions. They never need the password.

D2: Better AI prompt

> Act as a cybersecurity analyst. Review only the fictional email and synthetic sign-in logs that I paste below. Find the warning signs, build a timeline and suggest proportionate response actions. Keep observed facts separate from interpretations and assumptions. Say what the evidence cannot show, including who is behind an IP address. Do not visit the sample links, ask for or repeat passwords or OTPs, use real personal data, or suggest deleting evidence. Check security claims against the assessment's references and state any uncertainty.

D3: Corrected security advice (134 words)

Do not treat the scholarship email as safe. It creates urgency, asks for a college password and OTP, discourages contacting the college, and asks for a photo of an identity card. HTTPS does not prove a site is genuine, and a display name can be faked. Verify the scholarship through the official college portal or a contact you found yourself. The sign-in logs show failed passwords followed by a success, an MFA denial and approval, and a new session. With the student's statement, this raises concern about unauthorised access. But the logs do not identify who was behind the IP address or show what happened after the session started. IT should end active sessions, secure the account, preserve the logs and review later activity. Never send a password or OTP to anyone, including support.

D4: AI-use declaration and evidence notes

AI-use declaration: I used Claude and ChatGPT (AI assistants) to help organise, review and edit my draft and to explain cybersecurity concepts. I reviewed the content and am responsible for the final submission.

Evidence and reference notes

1. **CISA, Secure Our World.** It supports basic practices such as strong, unique passwords with a password manager, multifactor authentication, recognising phishing and installing updates. I used it for Tasks A and B. Backups, email authentication checks and the incident steps are my own reasoning, not from this page.
2. **NIST AI 600-1, Generative AI Profile.** It covers risks of generative AI, including confabulation (confident but false output). I used it for Task D: AI security advice should be checked against the evidence, not accepted automatically.

References

- CISA. Secure Our World. https://www.cisa.gov/secure-our-world [22/10/2026]
- NIST. Artificial Intelligence Risk Management Framework: Generative Artificial Intelligence Profile (NIST AI 600-1). https://nvlpubs.nist.gov/nistpubs/ai/NIST.AI.600-1.pdf [22/10/2026]